

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN
BỘ MÔN HỆ THỐNG THÔNG TIN

BÁO CÁO CÁ NHÂN
TÌM HIỂU VÀ THỰC HÀNH TÍCH HỢP
ZALOPAY API TRONG MÔI TRƯỜNG SANDBOX

Môn học: Thương mại điện tử

Sinh viên thực hiện:
Phạm Phát Lộc - 23127085

Giảng viên hướng dẫn:
Lương Văn Minh và Nguyễn Đức Huy

Thành phố Hồ Chí Minh, tháng 8 năm 2026

MỤC LỤC

Nội dung	Trang
1. Giới thiệu	1
2. Tổng quan ZaloPay API	1
2.1. Mô hình tích hợp thanh toán qua API	1
2.2. Phân biệt Sandbox và Production	2
2.3. Thông tin cấu hình	2
3. Quy trình thanh toán ZaloPay	3
4. API tạo đơn hàng	4
4.1. Đặc tả request	4
4.2. Mã tham chiếu giao dịch	5
4.3. Tạo chữ ký MAC	5
5. Callback và bảo mật	6
6. QR động ZaloPay	7
7. Hướng dẫn demo tối thiểu	8
8. Đánh giá	10
9. Kết luận	11
Tài liệu tham khảo	12

1. Giới thiệu

ZaloPay là nền tảng thanh toán điện tử tại Việt Nam, hỗ trợ thanh toán trên ứng dụng, website và điểm bán. Với lập trình viên, ZaloPay cung cấp API để hệ thống tạo yêu cầu thanh toán, chuyển người dùng vào luồng thanh toán và tiếp nhận kết quả giao dịch từ phía máy chủ.

Báo cáo này tìm hiểu quy trình tích hợp ZaloPay API ở mức tối thiểu nhưng đầy đủ về mặt kỹ thuật: tạo giao dịch trên backend, nhận order_url, hiển thị trang thanh toán hoặc QR động, tiếp nhận callback và xác thực kết quả bằng HMAC-SHA256. Trọng tâm là chỉ ghi nhận đơn hàng khi dữ liệu phía máy chủ đã được xác minh.

Toàn bộ nội dung thực hành sử dụng ZaloPay Sandbox, là môi trường dành cho học tập và kiểm thử với dữ liệu mô phỏng, không phát sinh giao dịch tiền thật.

2. Tổng quan ZaloPay API

2.1. Mô hình tích hợp thanh toán qua API

Trong mô hình tích hợp qua API, ứng dụng không trực tiếp xử lý thông tin thanh toán nhạy cảm. Backend chuẩn bị đơn hàng, ký request bằng khóa bí mật và gửi yêu cầu tới ZaloPay. Khi request hợp lệ, ZaloPay trả về dữ liệu để người dùng tiếp tục thanh toán; sau đó hệ thống ZaloPay gọi callback đến backend để thông báo kết quả.

Mô hình tạo thành hai luồng riêng: luồng trình duyệt phục vụ trải nghiệm người dùng qua order_url và Redirect URL; luồng server-to-server dùng callback để xác nhận kết quả. Backend cần lưu mã giao dịch nội bộ để liên kết hai luồng và tránh cập nhật nhầm đơn.

2.2. Phân biệt Sandbox và Production

Môi trường	Mục đích	Đặc điểm sử dụng
Sandbox	Học tập, phát triển và kiểm thử luồng tích hợp.	Dùng App ID và khóa Sandbox; dữ liệu thanh toán chỉ mang tính thử nghiệm.
Production	Tiếp nhận giao dịch thực tế.	Dành cho merchant/doanh nghiệp đã hoàn tất đăng ký, kiểm tra và được cấp thông tin chính thức.

Endpoint tạo đơn minh họa trong báo cáo: POST <https://sb-openapi.zalopay.vn/v2/create>

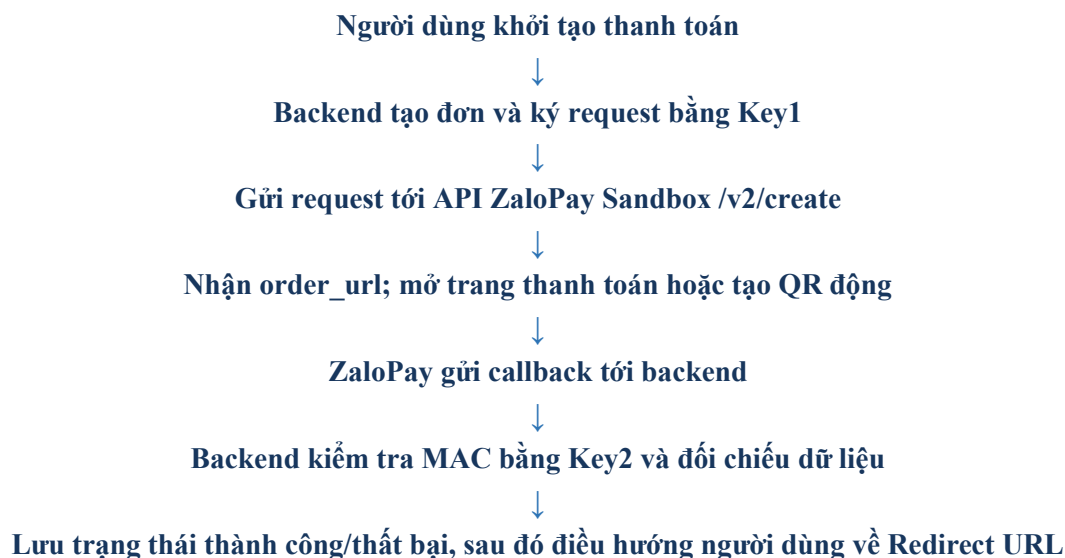
2.3. Thông tin cấu hình

Biến cấu hình	Vai trò
ZALOPAY_APP_ID	Định danh ứng dụng Sandbox hoặc merchant do ZaloPay cấp.
ZALOPAY_KEY1	Khóa tạo chữ ký MAC cho request gửi tới ZaloPay.
ZALOPAY_KEY2	Khóa kiểm tra chữ ký MAC của callback nhận từ ZaloPay.
ZALOPAY_API_URL	Địa chỉ API tạo đơn của môi trường đang sử dụng.
ZALOPAY_CALLBACK_URL	Endpoint backend công khai để nhận kết quả giao dịch.
ZALOPAY_REDIRECT_URL	Trang người dùng quay lại sau khi hoàn tất hoặc hủy thanh toán.

Key1 và Key2 là thông tin bảo mật phía máy chủ; không được đưa vào frontend, kho mã nguồn công khai, ảnh minh họa hoặc phụ lục. Báo cáo không sử dụng bất kỳ giá trị khóa thật nào.

3. Quy trình thanh toán ZaloPay

Luồng thanh toán tối thiểu được mô tả như sau:



Hình 1. Luồng thanh toán ZaloPay Sandbox trong demo tối thiểu

Redirect URL chỉ phục vụ điều hướng và hiển thị kết quả. Người dùng có thể tự mở lại trang này khi giao dịch chưa hoàn tất, vì vậy đây không phải là bằng chứng thanh toán đáng tin cậy. Callback đã xác thực MAC và được đối chiếu với dữ liệu nội bộ mới là căn cứ xác nhận giao dịch.

4. API tạo đơn hàng

4.1. Đặc tả request

API tạo đơn dùng phương thức POST tại path /v2/create. Request minh họa được gửi dưới định dạng application/x-www-form-urlencoded.

Tham số	Ý nghĩa
app_id	Mã ứng dụng ZaloPay được cấp cho môi trường tích hợp.
app_trans_id	Mã giao dịch do hệ thống tự tạo, có tiền tố ngày hiện tại và không trùng trong ứng dụng.
app_user	Mã hoặc thông tin định danh người dùng thực hiện giao dịch.
app_time	Thời điểm tạo đơn dưới dạng Unix timestamp, tính bằng millisecond.
amount	Số tiền thanh toán, đơn vị VND.
item	Danh sách sản phẩm hoặc dịch vụ dưới dạng chuỗi JSON.
embed_data	Dữ liệu bổ sung dạng JSON; có thể chứa redirecturl.
description	Nội dung mô tả đơn hàng hiển thị trong luồng thanh toán.
bank_code	Kênh thanh toán; có thể để trống tùy mô hình.
mac	Chữ ký HMAC-SHA256 bảo vệ tính toàn vẹn của request.

4.2. Mã tham chiếu giao dịch

app_trans_id có quy ước dạng YYMMDD_XXX. Ví dụ:

```
260828_demo001
```

Trong ví dụ này, 260828 biểu diễn ngày 28/08/2026; demo001 là phần mã riêng giúp tránh trùng lặp. Trong ứng dụng thực tế, phần mã riêng nên được sinh bằng ID đủ mạnh hoặc lấy từ khóa chính duy nhất thay vì tăng thủ công.

4.3. Tạo chữ ký MAC

Dữ liệu đầu vào phải ghép đúng thứ tự và giữ nguyên nội dung của embed_data, item:

```
data = app_id|app_trans_id|app_user|amount|app_time|embed_data|item
mac = HMAC_SHA256(Key1, data)
```

Key1 chỉ nên được đọc từ biến môi trường khi chạy backend. Đặt khóa trực tiếp trong mã nguồn làm tăng nguy cơ lộ secret qua lịch sử phiên bản, log hoặc gói frontend.

5. Callback và bảo mật

5.1. Cấu trúc callback

Sau khi giao dịch hoàn tất, ZaloPay gửi callback đến endpoint mà backend cung cấp. Callback có Content-Type: application/json và thường có ba trường bao ngoài:

Trường	Ý nghĩa
data	Chuỗi JSON chứa dữ liệu giao dịch được callback.
mac	Chữ ký dùng để xác minh tính hợp lệ của trường data.
type	Loại callback; với callback đơn hàng, thường có giá trị 1.

Khi phân tích data, backend có thể nhận các trường như app_trans_id, amount, zp_trans_id, app_time, server_time và channel. Không nên ghi toàn bộ payload vào log khi có dữ liệu không cần thiết.

5.2. Xác thực callback

Backend cần tính HMAC trực tiếp trên chuỗi data nhận được, không phải trên đối tượng JSON đã parse rồi serialize lại:

```
expected_mac = HMAC_SHA256(Key2, data)
```

Nếu MAC sai, backend phải từ chối callback và không cập nhật trạng thái giao dịch. Nếu MAC đúng, backend tiếp tục tìm giao dịch theo app_trans_id, kiểm tra số tiền đã lưu, zp_trans_id và trạng thái hiện tại. Xử lý nên có tính idempotent để callback lặp không tạo thêm tác vụ nghiệp vụ.

6. QR động ZaloPay

QR động trong luồng này không phải QR nhận tiền cá nhân. Sau khi API tạo đơn thành công, ZaloPay trả về order_url; ứng dụng có thể dùng thư viện QR để mã hóa nguyên văn URL này. Khi người dùng quét mã, ứng dụng thanh toán sẽ mở đúng luồng giao dịch đã được tạo.

Mỗi QR động gắn với một yêu cầu thanh toán cụ thể qua order_url, số tiền và app_trans_id. QR Sandbox chỉ phục vụ giao dịch thử nghiệm, không thay thế QR tĩnh nhận tiền tại quầy của merchant.

1. Backend tạo đơn Sandbox và nhận order_url.
2. Frontend/trang demo mã hóa nguyên văn order_url thành QR.
3. Người dùng quét QR và thực hiện giao dịch thử nghiệm.
4. Backend nhận callback, xác thực MAC rồi mới hiển thị trạng thái hoàn tất.

7. Hướng dẫn demo tối thiểu

7.1. Clip demo

Tên clip: 23127085-Zalopay. Liên kết YouTube: <https://youtu.be/mzfwhj3oZZY>

7.2. Bước 1: Chuẩn bị thông tin Sandbox

Đăng ký hoặc nhận App ID, Key1 và Key2 theo hướng dẫn Sandbox. Lưu thông tin trong biến môi trường của backend, giới hạn quyền truy cập và kiểm tra đúng cặp App ID/khóa của cùng môi trường.

7.3. Bước 2: Cấu hình biến môi trường

```
ZALOPAY_APP_ID="YOUR_SANDBOX_APP_ID"
ZALOPAY_KEY1="YOUR_KEY1"
ZALOPAY_KEY2="YOUR_KEY2"
ZALOPAY_API_URL="https://sb-openapi.zalopay.vn/v2/create"
ZALOPAY_CALLBACK_URL="https://your-public-domain/payments/zalopay/callback"
ZALOPAY_REDIRECT_URL="http://localhost:3000/payments/return/zalopay"
```

Callback URL phải là endpoint backend công khai để ZaloPay gửi POST từ bên ngoài. Redirect URL có thể là localhost trong lúc demo giao diện, nhưng localhost không phù hợp cho callback.

7.4. Bước 3: Tạo đơn hàng

Backend sinh app_trans_id duy nhất, chuẩn bị amount, item, embed_data và description. Sau đó ghép chuỗi đúng thứ tự, tạo MAC bằng Key1 và gửi POST form-urlencoded. Khi return_code = 1, lấy order_url từ phản hồi để tiếp tục.

7.5. Bước 4: Hiển thị và thanh toán

Trang demo mở trực tiếp order_url hoặc tạo QR động từ URL này. Trong khi chưa nhận callback, giao diện nên hiển thị trạng thái đang chờ.

7.6. Bước 5: Nhận callback

Backend nhận data và mac, tính expected_mac bằng Key2 và so sánh an toàn. Nếu hợp lệ, đổi chiều mã tham chiếu, số tiền, lưu trạng thái và zp_trans_id. Nếu không hợp lệ, trả phản hồi thất bại và giữ nguyên trạng thái cũ.

7.7. Bước 6: Kiểm tra kết quả

Điểm kiểm tra	Kết quả mong đợi	Xử lý khi không đạt
Tạo đơn Sandbox	return_code = 1 và có order_url.	Kiểm tra App ID, endpoint, dữ liệu MAC và định dạng request.
Mã tham chiếu	Đúng dạng ngày và không trùng.	Thay cơ chế sinh mã riêng; kiểm tra múi giờ Việt Nam.
Callback hợp lệ	MAC đúng, mã và số tiền khớp.	Kiểm tra Key2, chuỗi data nguyên văn và callback URL.
Callback giả mạo	Bị từ chối, trạng thái không đổi.	Không bỏ qua so sánh MAC và đối chiếu dữ liệu nội bộ.
Callback lặp	Chỉ ghi nhận một lần.	Bổ sung kiểm tra trạng thái và ràng buộc duy nhất cho giao dịch.

Bảng 1. Danh sách kiểm tra cho demo ZaloPay Sandbox

8. Đánh giá

8.1. Ưu điểm

- Hỗ trợ luồng trang thanh toán và QR động; order_url có thể dùng cho cả chuyển tiếp và tạo QR.
- Sandbox giúp kiểm thử quy trình trước khi tiếp cận Production.
- Callback server-to-server đáng tin cậy hơn redirect phía trình duyệt.
- HMAC-SHA256 cùng Key1/Key2 bảo vệ tính toàn vẹn và nguồn gốc dữ liệu.

8.2. Hạn chế

- Callback URL cần truy cập công khai; khi triển khai nên dùng HTTPS và domain ổn định.
- Khóa bí mật cần được quản lý kỹ trong phát triển, triển khai và ghi log.
- Sandbox không thay thế toàn bộ quy trình đăng ký, kiểm tra và vận hành Production.
- QR Sandbox chỉ phục vụ giao dịch thử nghiệm, không phải QR nhận tiền vào ví cá nhân.

8.3. Bài học rút ra

Điểm quan trọng nhất là thiết kế mã giao dịch duy nhất ngay từ đầu và dùng mã này để đối chiếu mọi thông báo. Backend cần xác thực callback, kiểm tra số tiền và ngăn xử lý lặp trước khi ghi nhận thành công. Secret phải được tách khỏi frontend và mã nguồn; trạng thái hiển thị cho người dùng phải phản ánh dữ liệu đã được backend xác minh.

9. Kết luận

Báo cáo đã trình bày quy trình tích hợp ZaloPay API trong Sandbox từ chuẩn bị cấu hình, tạo đơn /v2/create, tạo MAC bằng Key1, xử lý order_url/QR động đến tiếp nhận và xác thực

callback bằng Key2. Một tích hợp thanh toán đúng không chỉ mở được giao diện thanh toán mà còn phải xác minh kết quả bằng dữ liệu server-to-server.

ZaloPay Sandbox phù hợp để thực hành tạo mã tham chiếu, ký HMAC-SHA256, quản lý trạng thái và kiểm tra callback mà không phát sinh tiền thật. Hướng phát triển tiếp theo là hoàn tất quy trình merchant Production, bổ sung API tra cứu trạng thái khi callback đến trễ và nghiên cứu luồng hoàn tiền theo đặc tả chính thức.

Tài liệu tham khảo

- [1] ZaloPay Developer Documentation, Tổng quan tích hợp ZaloPay.
<https://developers.zalopay.vn/v2/general/overview.html>
- [2] ZaloPay Documentation, Tạo đơn hàng. <https://docs.zalopay.vn/docs/specs/order-create/>
- [3] ZaloPay Documentation, Callback. <https://docs.zalopay.vn/vi/docs/developer-tools/knowledge-base/callback/>
- [4] ZaloPay Documentation, Bảo mật truyền dữ liệu. <https://docs.zalopay.vn/vi/docs/developer-tools/security/secure-data-transmission/>
- [5] ZaloPay Documentation, Mã QR động. <https://docs.zalopay.vn/vi/docs/guides/payment-acceptance/qrcode/dynamic-qr/>
- [6] ZaloPay Developer Documentation, Hướng dẫn QR tĩnh.
<https://developers.zalopay.vn/v2/docs/staticqr/tutorial.html>